Cyber Security Safeguards – Overview

Cyber security Safeguards

Cyber security safeguards are **protective measures, policies, and technologies** designed to defend computer systems, networks, and data from threats, vulnerabilities, and attacks. They ensure **confidentiality, integrity, and availability (CIA)** of digital resources.

Types of Safeguards

A) Technical Safeguards

Protect systems using hardware and software controls.

- **Firewalls:** Monitor and filter incoming/outgoing network traffic.
- **Intrusion Detection & Prevention Systems (IDS/IPS):** Detect abnormal activities and block attacks.
- **Encryption:** Secure data in transit (TLS/SSL, VPNs) and at rest (AES, RSA).
- **Access Control Mechanisms:** Passwords, biometrics, smart cards, multi-factor authentication (MFA).
- **Anti-virus / Anti-malware Tools:** Detect and remove malicious software.
- **Patch Management:** Regular updates to fix vulnerabilities.

B) Administrative Safeguards

Policies, procedures, and practices to govern security.

Security Policies: Define acceptable use of password rules, data handling.
Risk Assessment: Identify and mitigate vulnerabilities.
Incident Response Plans: Steps to detect, contain, and recover from breaches.
User Training & Awareness: Educating employees against phishing, social engineering.
Auditing & Compliance: Regular checks for adherence to standards (ISO 27001, GDPR, HIPAA).

C) Physical Safeguards

Protect hardware and infrastructure.

- **Access Controls:** Locks, biometric systems, security guards.
- **Surveillance Systems:** CCTV, motion detectors.
- **Environmental Controls:** Fire suppression, cooling, backup power systems.
- **Device Security:** Prevent theft or tampering of servers, laptops, and mobile devices.

Safeguards by Layer

- **Network Layer:** Firewalls, VPNs, intrusion detection, segmentation.
- **Application Layer:** Secure coding practices, input validation, application firewalls.
- **Data Layer:** Encryption, database activity monitoring, data loss prevention (DLP).
- **User Layer:** Awareness programs, identity management, role-based access control.

Preventive, Detective, and Corrective Measures

- **Preventive:** Stop attacks before they occur (e.g., firewalls, strong authentication).

- **Detective:** Identify attacks in progress (e.g., IDS, log monitoring).

- **Corrective:** Restore systems after incidents (e.g., backups, disaster recovery plans).

Importance of Safeguards

- Protects critical infrastructure (power, healthcare, banking)
- Prevents data breaches and financial losses
- Maintains trust in digital services
- Ensures regulatory compliance
- Safeguards national security

Access control

Definition

- Access control is a **security mechanism** that regulates **who (users, devices, processes)** can access **what (resources, files, systems)** under **which conditions**.
- It enforces policies of **confidentiality, integrity, and availability (CIA)** by ensuring only authorized actions are permitted.

Key Functions of Access Control

- **Identification** – Claiming an identity (username, ID card, biometrics).
- **Authentication** – Verifying the identity (passwords, OTP, fingerprint).
- **Authorization** – Granting permissions (read, write, execute).
- **Accountability (Auditing)** – Tracking user actions (logs, monitoring).

Types of Access Control

A) Discretionary Access Control (DAC)

- Resource owners decide who can access their resources.
- Example: File permissions in Windows/Linux (read, write, execute).
- **Advantage:** Flexible.
- **Disadvantage:** Risk of privilege misuse.

B) Mandatory Access Control (MAC)

- Access decisions enforced by a **central authority** based on security labels.
- Example: Military systems (Top Secret, Secret, Confidential).
- **Advantage:** Strong security.
- **Disadvantage:** Rigid and less user-friendly.

C) Role-Based Access Control (RBAC)

- Access is based on the **role** of the user in an organization.
- Example:
  - Doctor: Can view/edit patient records.
  - Nurse: Can view records only.
- **Advantage:** Scalable and widely used in enterprises.

D) Attribute-Based Access Control (ABAC)

- Uses **attributes** (user, resource, environment).
- Example: Policy – “Allow access only if user is a Manager, from Office IP, during 9 AM–5 PM.”
- **Advantage:** Very flexible and policy-driven.

Access Control Models

- **Rule-Based Access Control:** Based on system rules (firewall rules, IP filtering).
- **Time-Based Access Control:** Access allowed only at specific times.
- **Context-Aware Access Control:** Based on device, location, or behavior.

Access Control Mechanisms

- **Passwords & PINs** – Simple but vulnerable.
- **Biometrics** – Fingerprint, iris scan, face recognition.
- **Smart Cards / Tokens** – Hardware-based identity.
- **Multi-Factor Authentication (MFA)** – Combination of factors (something you know, have, are).
- **Single Sign-On (SSO):** One login grants access to multiple systems.

Importance of Access Control

- Prevents unauthorized access and data breaches.
- Ensures compliance with regulations (HIPAA, GDPR, ISO 27001).
- Protects intellectual property and critical infrastructure.
- Enhances accountability through audit logs.

Cyber Security Audit

- A cyber security audit is a systematic evaluation of an organization's IT infrastructure, policies, and practices to ensure compliance with security standards and to detect risks, vulnerabilities, and inefficiencies.

- It ensures that security controls are effective and that data protection laws and standards (ISO 27001, NIST, GDPR, HIPAA, PCI DSS, etc.) are followed.

Objectives of Cyber Security Audit

- Assess the effectiveness of **security controls**.
- Ensure **confidentiality, integrity, and availability (CIA)** of information.
- Verify **compliance** with laws, policies, and industry standards.
- Provide recommendations for **risk management and mitigation**.
- Identify **vulnerabilities, misconfigurations, and insider threats**.

Types of Security Audits

A) Internal Audit
- Conducted by in-house security team or internal auditors.
- Focus: Policies, procedures, and compliance readiness.

B) External Audit
- Conducted by third-party organizations.
- Focus: Independent verification and certification (ISO 27001, PCI DSS).

C) Compliance Audit
- Checks adherence to **legal and regulatory standards**.
- Example: GDPR audit for data privacy, HIPAA audit for healthcare.

D) Technical Audit
- In-depth **system and network testing**.
- Includes penetration testing, vulnerability assessment, and log analysis.

Cyber Security Audit Process

1.Planning & Scope

1. Define scope (network, applications, policies, cloud).
2. Identify compliance standards to check against.

2.Data Collection & Review

1. Collect policies, security architecture, access control lists.
2. Interview staff and review logs.

3.Technical Assessment

1. Vulnerability scans, penetration testing, firewall/IDS/IPS review.
2. Check encryption, authentication, patching.

4.Analysis & Reporting

1. Identify gaps, weaknesses, and risks.
2. Rank risks as **high, medium, low**.

5.Recommendations & Remediation

1. Suggest improvements: patching, training, policy updates.
2. Follow-up audits to verify fixes.

Key Audit Tools

- **SIEM (Security Information and Event Management):** Splunk, QRadar.
- **Vulnerability Scanners:** Nessus, OpenVAS.
- **Compliance Tools:** Qualys, AuditBoard.
- **Log Analysis:** ELK Stack (Elasticsearch, Logstash, Kibana).

Benefits of Cyber Security Audits

- Detect vulnerabilities **before attackers exploit them**.
- Strengthen trust with customers and partners.
- Avoid legal penalties from **non-compliance**.
- Improve overall **security posture**.
- Provide a roadmap for **continuous improvement**.

Authentication

Definition

- Authentication is the process of **verifying the identity** of a user, device, or system before granting access to resources.

- It ensures that the entity requesting access is **who they claim to be**

Steps in Authentication

1. **Identification** – User claims identity (e.g., username, ID).

2. **Authentication** – System verifies identity (e.g., password, biometrics).

3. **Authorization (next step)** – Once verified, access is granted based on permissions

Authentication Factors

Authentication is usually classified into **three main factors**:

1.Something You Know

1. Passwords, PINs, security questions.
2. Weakness: Susceptible to guessing, phishing, brute-force attacks.

2.Something You Have

1. Smart cards, hardware tokens, OTP via mobile, USB keys.
2. More secure, but can be stolen or cloned.

3.Something You Are

1. Biometrics: fingerprint, iris, voice, facial recognition.
2. Strong, but privacy concerns and spoofing risks exist.

Advanced Authentication Models

- **Single-Factor Authentication (SFA):** Only one factor (e.g., password).

- **Two-Factor Authentication (2FA):** Combines two factors (e.g., password + OTP).

- **Multi-Factor Authentication (MFA):** Uses two or more factors, strongest form.

- **Single Sign-On (SSO):** One login gives access to multiple apps (e.g., Google account).

- **Federated Identity Management (FIM):** Cross-organization authentication (SAML, OAuth).

- **Zero Trust Authentication:** Verifies every request continuously (not just at login).

Authentication Protocols

- **Kerberos:** Ticket-based authentication in networks.
- **RADIUS & TACACS+:** Used in remote and enterprise authentication.
- **OAuth 2.0 & OpenID Connect:** Widely used in web/mobile apps.
- **SAML (Security Assertion Markup Language):** Used for SSO across domains.

Threats to Authentication

- **Password Attacks:** Brute force, dictionary attacks, phishing.
- **Session Hijacking:** Stealing active sessions (cookies).
- **Man-in-the-Middle (MitM):** Intercepting authentication traffic.
- **Credential Stuffing:** Using leaked credentials across sites.
- **Biometric Spoofing:** Fake fingerprints or face masks.

Best Practices in Authentication

- Use **strong, unique passwords** + enforce rotation.
- Implement **MFA** wherever possible.
- Limit login attempts & use **account lockouts**.
- Employ **biometrics + device-based authentication**.
- Monitor and log authentication attempts (audit trails).
- Use **encryption (TLS/SSL)** to secure authentication data.

Biometrics

Definition

- Biometrics refers to **automated methods of recognizing individuals** based on their **unique biological or behavioral characteristics**.
- It is widely used for **authentication, access control, and identity verification**.

Types of Biometrics

A) Physiological Biometrics (based on physical traits)

- **Fingerprint Recognition** – Most common, used in phones, access systems.
- **Iris Recognition** – Highly accurate, hard to forge.
- **Retina Scan** – Unique but intrusive, rarely used.
- **Facial Recognition** – Widely used (phones, surveillance), but prone to spoofing.
- **Hand Geometry** – Shape/size of hands, used in older systems.
- **DNA Recognition** – Extremely accurate, but slow and privacy-sensitive.

B) Behavioral Biometrics (based on patterns of behavior)

- **Voice Recognition** – Used in banking call centers, smart assistants.
- **Keystroke Dynamics** – Typing speed, rhythm, and pressure.
- **Gait Recognition** – Identifying people by how they walk.
- **Signature Recognition** – Analyzes signing style, not just static shape.

Biometric System Components

1. **Sensor** – Captures raw biometric data (camera, fingerprint scanner, mic).
2. **Feature Extraction Unit** – Converts raw data into a digital template.
3. **Database/Storage** – Stores biometric templates securely.
4. **Matcher** – Compares input with stored template.
5. **Decision Unit** – Grants or denies access.

Biometric System Modes

- **Verification (1:1 Match):** Confirms if the claimed identity matches stored template.
- **Identification (1:N Match):** Finds a person by comparing against a database.

- **Advantages of Biometrics**
- Unique and hard to forge.
- No need to remember passwords or carry tokens.
- Enhances user convenience and security.
- Provides **continuous authentication** (e.g., behavioral monitoring).

- **Limitations of Biometrics**
- **False Accept Rate (FAR):** Unauthorized person accepted.
- **False Reject Rate (FRR):** Authorized person denied.
- Privacy concerns (data theft → irreversible).
- Costly hardware and infrastructure.
- Vulnerable to spoofing (fake fingerprints, face masks, voice recordings).

- **Security & Privacy Concerns**
- Biometric data, once compromised, **cannot be changed** (unlike passwords).
- Risk of misuse in **surveillance and profiling**.
- Requires **encryption & secure storage** of biometric templates.
- Adoption of **multi-factor authentication (MFA)** with biometrics is recommended.

Applications of Biometrics

- **Smartphones** (fingerprint, facial unlock).
- **Banking & Payments** (fingerprint ATMs, biometric cards).
- **Airports & Border Security** (e-passports, e-gates).
- **Workplace & Attendance Systems.**
- **Healthcare** (patient ID verification).
- **IoT & Smart Homes** (biometric locks, assistants).

Denial of Service (DoS)

A **Denial of Service (DoS) attack** is a malicious attempt to make a machine, network, or service **unavailable** to its intended users by **flooding it with traffic or triggering resource exhaustion**.

Types of DoS Attacks

1.Volume-based Attacks

1. Flood the target with massive amounts of traffic.
2. Example: ICMP Flood, UDP Flood, Ping of Death.

2.Protocol Attacks

1. Exploit weaknesses in network protocols.
2. Example: SYN Flood, Smurf Attack, Fragmented Packet Attack.

3.Application-layer Attacks

1. Target specific applications or services.
2. Example: HTTP Flood, Slowloris attack.

4.Distributed Denial of Service (DDoS)

1. An advanced form where multiple compromised systems (**botnets**) launch an attack simultaneously.
2. Harder to stop because the traffic comes from many sources.

Distributed Denial of Service (DDoS)

- Performed using a botnet (network of infected computers/IoT devices).
- Attack traffic comes from multiple sources, making it harder to block.
- Example: Mirai Botnet (2016) – took down Twitter, Netflix, GitHub.

Famous DoS/DDoS Attacks

- **1999:** First major DoS attack on a university network.
- **2000:** Attacks on Yahoo, eBay, CNN.
- **2016:** Mirai Botnet DDoS attack on DNS provider, disrupted major internet services.

Impact of DoS/DDoS

- Website downtime = financial loss.
- Reputational damage.
- Customer trust erosion.
- Service unavailability for critical sectors (banks, healthcare, govt).

DoS Attack Techniques

1. **Flood Attacks** – Overwhelm system with traffic.
2. **Amplification Attacks** – Small request triggers huge responses (DNS Amplification, NTP Amplification).
2. **Exploitation Attacks** – Exploit vulnerabilities (Teardrop, Land Attack).

Defense Mechanisms

- **Preventive Measures**
  - Firewalls & Intrusion Prevention Systems (IPS).
  - Rate limiting (limit requests per second).
  - Load balancing across multiple servers.
  - Using **Content Delivery Networks (CDN)**.
- **Detection**
  - Monitoring unusual traffic spikes.
  - Anomaly-based intrusion detection.
- **Mitigation**
  - Blackholing (dropping all traffic to attacked server).
  - Scrubbing centers (clean malicious traffic, forward good traffic).
  - Cloud-based DDoS protection (Cloudflare, Akamai, AWS Shield).

Ethical Hacking

- **Hacking**: Gaining unauthorized access to systems or data.
- **Ethical Hacking**: Also called **penetration testing** or **white-hat hacking**.
- Carried out **with permission** of the system owner.
- Purpose: Identify vulnerabilities before malicious hackers exploit them.
- Ethical hackers follow legal & professional guidelines.

Objectives of Ethical Hacking

- **Identify vulnerabilities** in software, hardware, or networks.
- **Test security controls** and policies.
- **Prevent data breaches** and cybercrimes.
- **Ensure compliance** with laws and standards (ISO 27001, GDPR, HIPAA, etc.).
- **Strengthen cyber defense**.

Phases of Ethical Hacking

Ethical hacking usually follows a **structured methodology**:

1.Reconnaissance (Information Gathering)

1. Passive: Social media, WHOIS, job postings.
2. Active: Ping sweeps, port scans.

2.Scanning and Enumeration

1. Identify live hosts, open ports, services.
2. Tools: Nmap, Nessus.

3.Gaining Access

1. Exploit vulnerabilities (SQL injection, buffer overflow).
2. Tools: Metasploit, Hydra.

4.Maintaining Access

1. Install backdoors or rootkits (for testing).

5.Covering Tracks

1. Clearing logs, removing test scripts.
2. Ethical hackers **report this step** rather than actually erase evidence.

6.Reporting

1. Document vulnerabilities, impact, and mitigation steps.

Tools Used in Ethical Hacking

- **Nmap** – Network scanning.
- **Metasploit** – Exploitation framework.
- **Wireshark** – Packet analysis.
- **Burp Suite** – Web app testing.
- **Aircrack-ng** – Wi-Fi security testing.
- **John the Ripper** – Password cracking.

Types of Ethical Hacking

- **Web Application Hacking** (SQLi, XSS).
- **System Hacking** (privilege escalation, Trojans).
- **Wireless Network Hacking** (Wi-Fi cracking).
- **Social Engineering** (phishing, impersonation).
- **Cloud Hacking** (API security, misconfigurations).
- **IoT Hacking** (smart devices).

Advantages of Ethical Hacking

- Helps organizations secure their networks.
- Protects sensitive data.
- Builds trust with customers.
- Identifies security gaps proactively.
- Aids in compliance and auditing.

Challenges / Limitations

- Legal & ethical boundaries must be maintained.
- Time-consuming and resource-intensive.
- Cannot guarantee **100% security**.
- Results depend on **scope of testing**.
- Requires highly skilled professionals.

Applications

- **Banking & Finance** – Prevent fraud.
- **Healthcare** – Protect patient data.
- **E-commerce** – Secure transactions.
- **Government/Military** – Cyber defense.
- **Cloud services** – Ensure secure infrastructure.

Firewall

- A **firewall** is a **security system (hardware or software)** that monitors and controls **incoming and outgoing network traffic** based on **predefined security rules**.
- It acts as a **barrier** between a trusted internal network and untrusted external networks (like the Internet).

Functions of a Firewall

•**Packet Filtering** – Checks each data packet against rules (IP, port, protocol).

•**Traffic Monitoring & Logging** – Keeps track of suspicious activity.

•**Access Control** – Allows or blocks connections based on policies.

•**VPN Support** – Provides secure remote access.

•**Intrusion Prevention** – Blocks malicious traffic (in modern firewalls).

Types of Firewalls

1. Packet-Filtering Firewall

- Works at **Network Layer** (Layer 3, OSI model).
- Filters based on **IP address, port, and protocol**.
- Fast, but cannot check payload (data inside).
- Example: ACLs (Access Control Lists) on routers.

2. Stateful Inspection Firewall

- Tracks the **state of active connections**.
- Ensures packets belong to a valid session.
- More secure than simple packet filtering.

3. Proxy Firewall (Application-Level Gateway)

- Works at **Application Layer**.
- Intercepts traffic and hides internal network.
- Provides **deep packet inspection** (checks content).
- Slower, but highly secure.

4. Next-Generation Firewall (NGFW)

- Combines features: **packet filtering + intrusion prevention + application awareness + threat intelligence**.
- Detects modern threats (malware, ransomware).

5. Cloud Firewall (Firewall as a Service, FWaaS)

- Firewall hosted in the **cloud**.
- Protects cloud applications and services.

- **Advantages**
  - Prevents unauthorized access.
  - Protects sensitive data.
  - Filters malicious traffic.
  - Enforces security policies.

- **Limitations**
  - Cannot protect against **internal threats**.
  - Cannot stop attacks via **malicious insiders or infected USBs**.
  - Needs constant updates for new threats.

Intrusion Detection Systems (IDS)

- An **Intrusion Detection System (IDS)** is a **security monitoring tool** that analyzes network traffic or system activities to **detect suspicious, malicious, or unauthorized activities**.
- It does not block traffic (like a firewall), but **alerts administrators** about potential threats.

Functions of IDS

- Monitor network & host activities.
- Detect malicious behavior (malware, policy violations, port scans).
- Log security events for analysis.
- Alert administrators in real time.
- Assist in forensic investigations.

Types of IDS

Type	Monitors	Detection Method	Advantages	Limitations
Network-based IDS (NIDS)	Network traffic at strategic points	Packet analysis	Covers large networks, detects attacks in transit	Struggles with encrypted traffic, high bandwidth overhead
Host-based IDS (HIDS)	Individual host (server/PC)	Monitors logs, system calls, file integrity	Detects insider misuse, specific host attacks	High resource usage, limited to one host
Signature-based IDS	Matches traffic to known attack signatures	Known attack patterns	Accurate for known threats	Cannot detect zero-day attacks
Anomaly-based IDS	Detects deviations from normal behavior	Machine learning/statistical models	Can detect new/unknown attacks	High false positives
Hybrid IDS	Combines signature + anomaly detection	Both methods	Balanced detection	Complex and resource-heavy

IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
Detects and alerts	Detects and blocks attacks
Passive monitoring	Active prevention
Sits out-of-band	Sits in-line with traffic
Example: Snort in IDS mode	Example: Snort in IPS mode, Cisco Firepower

Advantages

- Early warning of attacks.
- Detects suspicious internal activity.
- Helps in forensic analysis.
- Increases security awareness.

Limitations

- High false positives (especially anomaly-based).
- Cannot stop attacks (only detection).
- Struggles with encrypted traffic.
- Requires skilled staff to analyze alerts.

Security Policy

•A **Security Policy** is a formal set of rules and practices that govern how an organization manages, protects, and distributes its information assets.

•**Threat Management** refers to identifying, analyzing, and mitigating risks posed by internal and external threats.

•Together, they form the foundation of **Cybersecurity Governance**.

Objectives

•Protect confidentiality, integrity, and availability (CIA triad).

•Establish acceptable use of IT systems.

•Define responsibilities of employees, administrators, and management.

•Ensure compliance with legal and regulatory standards.

•Guide incident response and disaster recovery.

Types of Security Policies

1.Organizational Policy

1. Broad statement of security principles.
2. Example: “All sensitive data must be encrypted.”

2.System-Specific Policy

1. Rules for a particular system, network, or application.
2. Example: “Database servers must use AES encryption.”

3.Issue-Specific Policy

1. Focuses on specific concerns.
2. Example: Email usage policy, Bring Your Own Device (BYOD) policy.

Key Components of a Good Security Policy

- **Purpose**: Why the policy exists.
- **Scope**: Who/what it applies to.
- **Roles & Responsibilities**: Employees, admins, management.
- **Access Control Rules**: Authentication, authorization, least privilege.
- **Data Classification**: Public, internal, confidential, restricted.
- **Incident Response**: Steps for detection, reporting, recovery.
- **Compliance Requirements**: ISO 27001, GDPR, HIPAA, etc.
- **Review & Updates**: Policies must be regularly updated.

Threat Management

- **Threat Management** is the process of detecting, analyzing, prioritizing, and mitigating potential security threats.
- **Threats Classification**

1. **Natural Threats** – Earthquakes, floods, fires.
2. **Human Threats**
    1. Malicious: Hackers, insider threats, cybercriminals.
    2. Non-malicious: Human error, misconfigurations.
3. **Technical Threats** – Hardware failures, software bugs, power outages.

- **Threat Management Process**

1. **Threat Identification**
    1. Recognize vulnerabilities and attack vectors.
    2. Example: Open ports, weak passwords.
2. **Threat Analysis**
    1. Assess the severity, likelihood, and impact.
3. **Threat Prioritization**
    1. Rank threats (high, medium, low).
    2. Example: Ransomware = High, Printer downtime = Low.
4. **Mitigation / Control Measures**
    1. Preventive: Firewalls, access control, encryption.
    2. Detective: IDS, monitoring, auditing.
    3. Corrective: Patching, backups, disaster recovery.
5. **Monitoring & Review**
    1. Continuous monitoring using SIEM (Security Information and Event Management) tools.

- **Security Policy & Threat Management Relationship**
- A **Security Policy** defines **rules & responsibilities**.
- **Threat Management** ensures those rules are **enforced in practice**.
- Example:
  - Policy: “All users must use MFA.”
  - Threat Management: Detect brute force attacks and enforce account lockout.

- **Tools for Threat Management**
- **SIEM (Splunk, IBM QRadar)** – Log monitoring & threat detection.
- **Firewalls & IDS/IPS** – Network defense.
- **Endpoint Security (EDR)** – Detect endpoint malware.
- **Vulnerability Scanners (Nessus, OpenVAS)** – Identify weak points.
- **Threat Intelligence Feeds** – Track emerging threats.

Challenges in Threat Management

- Zero-day vulnerabilities (unknown threats).
- Sophisticated attacks (APTs, ransomware).
- Insider threats.
- Lack of skilled cybersecurity professionals.
- High cost of advanced tools.